Technical Report: Designing an Acceptable Use Policy for a Small Research Organisation

Field	Detail
Intern	Arpit Yadav
Intern ID	2415
Programme	RedKross Research Foundation — Internship, October 2026 batch
Task	Security Policy Writing: Acceptable Use Policy for a small research organisation
Deliverable	KRI-ISP-001 Acceptable Use Policy v1.0 (fictional organisation: Kestrelwood Research Institute)
Report date	October 2026

Contents

Abstract 2
1. Introduction and Objective 2
2. Background Research 2
3. Methodology 4
4. Tools and Technologies 5
5. Work Performed 6
6. Results 7
7. Testing and Evaluation 9
8. Limitations 10
9. Recommendations 10
10. Conclusion 11
11. References 11

Abstract

This report describes how an Acceptable Use Policy (AUP) was designed for Kestrelwood Research Institute (KRI), a fictional non-profit research organisation with about 30 users. The policy was built from the task brief, then mapped against ISO/IEC 27001/27002:2022, NIST SP 800-53 Rev. 5, related NIST guidance, CIS Controls v8.1 and Indian law, including the IT Act, 2000, the DPDP Act, 2023 and the CERT-In Directions, 2022.

The resulting policy has 16 sections and two appendices. It is supported by two process diagrams, two forms and two checklists. An automated check script was written and run against the policy. It confirmed that all 13 elements required by the brief are present, that all 10 internal cross-references are valid, and that no personal data appears in the repository.

The policy has not been reviewed by legal or HR professionals or tested with real users. These limitations are discussed in Section 8, together with recommendations for adopting the policy.

1. Introduction and Objective

1.1 Task statement

The assigned task was: *"Draft an acceptable-use policy for a small research organisation. Define scope, acceptable use, prohibited actions, account/device responsibilities, data handling, reporting, monitoring notice, and consequences/escalation."* The required deliverable was *"a professional policy document with purpose, scope, responsibilities, rules, exception process, and review date."*

1.2 Objectives

1. Produce a complete, professional AUP that covers every element in the brief.
2. Base the policy on recognised standards and applicable law, not on opinion.
3. Make the policy practical for a small organisation, with clear rules, specific timeframes and named contacts.
4. Provide supporting material that makes the policy usable: diagrams, forms and checklists.
5. Evaluate the policy honestly and document its limitations.

1.3 Why an AUP matters

An AUP is the document that turns an organisation's security goals into rules for everyday behaviour. People are central to most security failures. Verizon's *2024 Data Breach Investigations Report* found that 68% of breaches involved a non-malicious human element, such as falling for phishing or making an error. Formal "rules of behaviour" for users are a baseline control in both ISO/IEC 27002:2022 (control 5.10) and NIST SP 800-53 (control PL-4).

Small research organisations face a particular mix of risks:

- They hold sensitive research participant data and unpublished intellectual property.
- They have many short-term users, such as interns and visiting researchers.
- They usually have very little IT staff.

A clear AUP is one of the most cost-effective controls for organisations like this.

2. Background Research

2.1 Standards and frameworks reviewed

Source	What it contributed
ISO/IEC 27001:2022 and 27002:2022	Control 5.10 (acceptable use) is the anchor for the policy. Related controls shaped specific sections: 5.12–5.14 (classification, labelling, transfer), 5.17 (authentication information), 6.4 (disciplinary process), 6.7 (remote working), 6.8 (event reporting), 8.1 (user endpoint devices) and 8.15–8.16 (logging, monitoring).
NIST SP 800-53 Rev. 5	PL-4 Rules of Behavior (the formal basis for an AUP and its acknowledgement), AC-8 System Use Notification (the sign-in monitoring notice), PS-6 Access Agreements, PS-8 Personnel Sanctions (graduated consequences) and IR-6 Incident Reporting.
NIST SP 800-63B-4 (2025)	Password guidance: favour length and use password managers, do not force periodic changes without evidence of compromise, and use phishing-resistant MFA where possible.
NIST SP 800-61 Rev. 3 (2025)	Incident response as part of risk management. This informed the reporting steps and the "lessons learned" stage.
NIST SP 800-88 Rev. 2 (2025)	Media sanitisation, referenced for secure device disposal.
CIS Controls v8.1	A prioritised, practical view suited to small organisations. In particular: Control 3 (Data Protection), 5 (Account Management), 14 (Security Awareness) and 17 (Incident Response Management).
SANS AUP template	A comparison of common AUP structure and wording.

2.2 Legal context (India)

RedKross Research Foundation is based in India, so the fictional KRI was assumed to operate under Indian law.

- **Information Technology Act, 2000.** Defines offences such as unauthorised access and data theft. This is relevant to Level 4 breaches.
- **Digital Personal Data Protection Act, 2023.** Governs the processing of personal data, including research participant data. It shaped data minimisation, purpose limitation and breach notification.
- **CERT-In Directions (28 April 2022) under section 70B(6) of the IT Act.** Require specified cyber incidents to be reported to CERT-In within 6 hours, and ICT system logs to be kept for 180 days. The policy's 12-month log retention exceeds this.
- **GDPR.** Mentioned for projects involving EU participants.

2.3 Key design insights from the research

1. **An AUP must balance control and trust.** Research organisations depend on openness. Rules that are too strict encourage people to work around them ("shadow IT"), so the policy explains *why* each rule exists and includes an exception route.
2. **Monitoring must be transparent and proportionate.** NIST AC-8 and data-protection principles both require users to be told about monitoring. The policy therefore lists what is monitored, what is *not* monitored, and who must approve access to content.
3. **Reporting needs a no-blame culture.** Fear of punishment delays reporting. The policy states that good-faith reports will not on their own lead to disciplinary action, while concealment is a breach.

4. **Consequences must be graduated and fair.** NIST PS-8 and ISO 6.4 call for a formal, proportionate sanctions process. A four-level model with a right of appeal was chosen.
5. **New risks need explicit rules.** Generative AI tools and personal cloud services are now common routes for data leakage, so they are covered explicitly in Sections 5.4–5.5.

3. Methodology

The work followed eight steps.

Step	Activity	Output
1. Requirement analysis	Broke the task brief down into 13 required elements	Traceability matrix (Section 6.1)
2. Background research	Reviewed the standards, laws and templates in Section 2	Source list and design insights
3. Organisation profiling	Defined a fictional but realistic organisation, so the policy could be specific without using real organisation data	KRI profile (Section 3.1)
4. Risk identification	Identified the main user-behaviour risks for a small research organisation	Risk-to-policy mapping (Section 3.2)
5. Drafting	Wrote the policy using requirement language (*must/should/may*), plain English, tables and specific timeframes	`policy/KRI-Acceptable-Use-Policy.md`
6. Supporting artefacts	Created process diagrams, an acknowledgement form, an exception form and checklists	`diagrams/`, `forms/`, `checklists/`
7. Evaluation	Wrote and ran an automated check script, and carried out a manual consistency review	`evaluation/policy-check-results.md`, Section 7
8. Publication	Exported DOCX and PDF versions, organised the GitHub repository and wrote the README	`policy/*.docx`, `policy/*.pdf`, `README.md`

3.1 Organisation profile (assumptions)

Attribute	Assumption
Name	Kestrelwood Research Institute (KRI). Fictional. Contact details use the reserved `.example` domain.
Size	About 30 users: researchers, research assistants, interns, visiting collaborators, operations staff and a two-person IT team
Data	Research participant personal data (some health-related), unpublished results, grant applications, HR and financial records
Technology	Cloud email and collaboration suite, managed laptops, staff and guest Wi-Fi, VPN, shared research server, computers attached to lab instruments, limited use of personal phones
Governance	Executive Director, Board of Trustees, an Information Security Lead (part-time role), HR

Attribute	Assumption
Jurisdiction	India, with occasional international collaborators

3.2 Key risks and policy response

Risk	Policy controls (section)
Phishing and credential theft	Passphrases, password manager and MFA; never approve unexpected MFA prompts; Report Phishing button (7.2, 7.3, 10.2)
Lost or stolen laptops and phones	Encryption, screen lock, report within 1 hour, remote wipe (8.1–8.3)
Data leakage through personal email, cloud services or AI tools	Approved Services List; no auto-forwarding; AI rules; classification-based handling (5.3–5.5, 9)
Mishandling of participant data	Restricted classification; data minimisation; pseudonymisation; no re-identification (6.2, 9.1, 9.2)
Unpatched or unmanaged devices	Updates within 7 days; BYOD minimum requirements; exceptions for lab instruments with compensating controls (8.1, 8.2, 13)
Insider misuse or unauthorised testing	Prohibited actions; written authorisation for security tools; monitoring; graduated sanctions (6, 11, 12)
Delayed or hidden incidents	No-blame reporting; concealment is a breach; clear contacts and timeframes (6.5, 10)
Leavers keeping access	Accounts disabled on the last working day; six-monthly access reviews (7.5)

4. Tools and Technologies

Tool	Purpose
Markdown	Source format for all documents. It is readable on GitHub and easy to track with version control.
Visual Studio Code	Editing
Python 3.13 and the `markdown` package	`tools/build_docs.py` (Markdown to HTML) and `tools/policy_check.py` (automated checks)
Microsoft Word (automated through PowerShell)	`tools/export_word.ps1` converts the HTML into formatted DOCX and PDF, with a table of contents, headers and page numbers
SVG and Microsoft Edge (headless mode)	Process diagrams drawn as SVG and rendered to PNG
Git and GitHub	Version control and submission
AI assistant (Claude)	Used for drafting support and structuring. All content was reviewed and checked against the cited sources by the author.

5. Work Performed

5.1 Policy structure

The policy (KRI-ISP-001 v1.0) has the following sections. Each one exists for a specific reason.

#	Section	Design rationale
—	Document control and version history	A professional policy needs an owner, an approver, an effective date and a review date (ISO 5.1)
1	Purpose, including how to read the policy	Explains why the rules exist. Defines *must / should / may* so the rules cannot be misread.
2	Scope	Covers all user types (including interns and visitors), all asset types (including BYOD), all locations, and the "stricter rule applies" principle for ethics approvals and contracts
3	Definitions	Removes ambiguity for non-technical readers
4	Roles and responsibilities	Without named owners, a policy is not enforced. Seven roles are defined.
5	Acceptable use	Positive rules first: general principles, limited personal use, email, cloud, **AI tools**, code and research computing, remote working, social media, clear desk
6	Prohibited actions	Grouped into five categories. Includes a controlled route for legitimate research, such as malware analysis.
7	Account responsibilities	Passphrases of 14 or more characters, password manager, MFA, prompt-bombing awareness, separate admin accounts, joiners/movers/leavers, API keys
8	Device responsibilities	KRI devices, BYOD minimum requirements (with a selective-wipe privacy assurance), loss reporting within 1 hour, removable media, travel, disposal
9	Data handling	Four-level classification table with examples and handling rules, participant data rules, sharing, storage, retention and disposal
10	Reporting	What, how and when (a tiered table), what to do and not do, no-blame reporting, what happens next (including CERT-In and DPDP notification), Figure 1
11	Monitoring notice	Why KRI monitors, what is monitored, **what KRI will not do**, approval rules for accessing content, privacy, log retention, sign-in banner
12	Consequences and escalation	Four breach levels with examples, a seven-step escalation process, right of reply and appeal
13	Exception process	What cannot be excepted, how to request, risk-based approval table, time limits, Exception Register, Figure 2
14	Policy review	Annual review (next due 1 November 2027) plus triggers for an earlier review
15	Acknowledgement	Mandatory before access is granted, and every year

#	Section	Design rationale
16	Related documents	Places the AUP within a wider policy framework
App. A	Quick reference (do / don't)	A one-table summary for awareness and posters
App. B	Exception request form (summary)	Links to the full form

5.2 Supporting artefacts

File	Description
`diagrams/incident-reporting-escalation.svg/.png`	Figure 1: from noticing an incident, through reporting, triage, the four breach levels and fair process, to lessons learned
`diagrams/exception-process.svg/.png`	Figure 2: request, risk assessment, risk-based approval, register and expiry
`forms/acknowledgement-form.md`	User acknowledgement with eight key-point tick boxes
`forms/exception-request-form.md`	Three-part form: requester, ISL risk assessment, decision
`checklists/user-onboarding-checklist.md`	13-item first-week checklist linked to policy sections
`checklists/policy-review-checklist.md`	Annual review checklist for the policy owner

5.3 Key design decisions

- **A fictional organisation** was used so the policy could be specific (names, numbers, contacts) without exposing any real organisation's information. This follows the instruction not to upload confidential or personal data.
- **Specific timeframes** were used instead of vague terms like "promptly":
  - 1 hour to report a lost device or account compromise;
  - 1 working day for triage;
  - 7 days to install updates;
  - 10 working days for exception decisions and appeals;
  - 12 months for log retention and the maximum length of an exception.
- **No forced password expiry**, following NIST SP 800-63B-4.
- **Explicit privacy limits on monitoring.** The policy states that there is no keystroke logging and no covert camera or microphone use, that BYOD monitoring covers only KRI apps, and that the Executive Director must approve any access to content. This builds trust and supports proportionality under the DPDP Act.
- **Generative AI rules** were included because unapproved AI tools are now a common route for data leakage.

6. Results

6.1 Requirement traceability

Every element in the task brief is covered.

Requirement from the brief	Policy section
Purpose	1
Scope	2
Responsibilities	4 (and 7, 8)
Rules: acceptable use	5
Rules: prohibited actions	6
Account responsibilities	7
Device responsibilities	8
Data handling	9
Reporting	10
Monitoring notice	11
Consequences and escalation	12
Exception process	13 and Appendix B
Review date	Document control table and Section 14 (1 November 2027)

6.2 Standards mapping

Policy section	ISO/IEC 27002:2022	NIST SP 800-53 Rev. 5	CIS Controls v8.1
4 Roles	5.2	PL-4, PS-6	—
5–6 Acceptable use / prohibited	5.10, 6.7	PL-4	14
7 Accounts	5.16, 5.17, 5.18, 8.2, 8.5	AC-2, IA-2, IA-5	5, 6
8 Devices	7.9, 7.10, 7.14, 8.1	AC-19, MP-6	4, 7, 10
9 Data handling	5.12, 5.13, 5.14, 5.34, 8.10	RA-2, MP-3	3
10 Reporting	5.24, 6.8	IR-6	17
11 Monitoring	8.15, 8.16	AC-8, AU-2, AU-11	8
12 Consequences	6.4	PS-8	—
13 Exceptions	5.1, 5.36	RA-3	—
14 Review	5.1	PL-1	—
15 Acknowledgement	6.2, 6.3	PL-4, PS-6	14

6.3 Final output

- A policy of about 5,400 words with 16 sections, 2 appendices, 11 tables and 2 figures, delivered as Markdown, DOCX and PDF.
- Six supporting artefacts: two diagrams, two forms and two checklists.
- A reproducible build process and check script in `tools/`.

7. Testing and Evaluation

A policy cannot be "executed" the way software can. The evaluation therefore consisted of an **automated document check** and a **manual consistency review**, both carried out on the final draft. No testing with real users, no legal review and no simulation exercise was performed (see Section 8).

7.1 Automated check (`tools/policy_check.py`)

The script was run on 18 October 2026. Full output is in `evaluation/policy-check-results.md`.

Check	Result
All 13 task-brief elements present as headings, plus a review date in document control	**PASS** (14/14)
Section cross-references point to real sections	**PASS**: 10 checked, 0 broken
Referenced figures exist	**PASS**: 2 of 2
Personal-data scan of all Markdown files (real email addresses or phone numbers)	**PASS**: 0 findings
Requirement statements	59 "must" (including 15 "must not" / "must never"), 11 "should"
Flesch Reading Ease (prose only)	**39.2** ("difficult", roughly university reading level)

7.2 Manual consistency review

The same values appear in several places (policy text, tables, diagrams, forms and checklists). These were checked by hand to make sure they agree:

Value	Appears in	Consistent?
Lost device or compromise: report within 1 hour	8.3, 10.2, Figure 1, onboarding checklist, acknowledgement form	Yes
Triage within 1 working day	10.2, 12.3, Figure 1	Yes
Appeal within 10 working days	12.3, Figure 1	Yes
Exception decision within 10 working days (2 if urgent); maximum 12 months	13.4, 13.5, Figure 2, exception form	Yes
Updates within 7 days	8.1, Appendix A	Yes
Passphrase at least 14 characters	7.2, onboarding checklist	Yes

Value	Appears in	Consistent?
Next review date 1 November 2027	Document control, 14, review checklist	Yes
Contacts: extension 4400, security@kestrelwood.example	10.2, 13.3, Appendix A, Figure 1, exception form, onboarding checklist	Yes

7.3 Interpretation

The policy is complete against the brief and internally consistent. The main weakness the evaluation found is **readability**. A score of 39.2 is typical for legal and policy texts, but it is harder to read than ideal for interns and non-technical users. Appendix A (Quick Reference) partly addresses this. A plain-language summary or short awareness module is recommended (Section 9).

The Flesch formula is only an approximation, and the script uses a heuristic syllable counter, so the score should be read as an indicator rather than a precise measurement.

8. Limitations

1. **Fictional organisation.** The policy reflects assumptions (Section 3.1), not a real organisation's systems, culture or risk assessment.
2. **No legal or HR review.** References to Indian law are summaries for context, not legal advice. Before adoption, a lawyer and HR must review the disciplinary and monitoring sections in particular.
3. **No stakeholder consultation or user testing.** Real users, PIs and IT staff were not consulted, and the policy's clarity was not measured with actual readers.
4. **Assumed technical controls.** The policy assumes KRI has device management, a password manager, VPN, MFA and an Approved Services List. A real small organisation may need to put these in place first.
5. **Not tested by simulation.** The reporting and escalation processes were not tested through a tabletop exercise.
6. **Readability.** As measured in Section 7, the text is relatively complex.
7. **Point-in-time accuracy.** Standards, laws and AI tools change. The references were correct as of October 2026.

9. Recommendations

1. **Legal and HR review** of Sections 11 (monitoring) and 12 (consequences) before adoption.
2. **Consultation and pilot.** Share the draft with a sample of researchers, interns and IT staff; trial it with one team; collect feedback.
3. **Awareness training.** Run a 20–30 minute session or e-learning module with a short quiz, based on Appendix A. Repeat it every year with the re-acknowledgement.
4. **Track acknowledgements** with a target of 100% of active users, and grant no access before acknowledgement.
5. **Technical enforcement.** Back the rules with controls: enforced MFA, device management, blocking auto-forwarding, and approved AI tools with data protections.
6. **Tabletop exercise.** Test Figure 1 with a realistic scenario, such as a lost laptop containing participant data, and measure the time to report and triage.
7. **Improve readability.** Produce a one-page plain-language version for new interns and visitors, aiming for a Flesch score above 50.

8. **Measure and review.** Use the metrics in `checklists/policy-review-checklist.md` for the annual review due on 1 November 2027.

10. Conclusion

The task was to draft an acceptable-use policy for a small research organisation. The resulting policy, KRI-ISP-001, covers every required element: purpose, scope, responsibilities, acceptable and prohibited use, account and device responsibilities, data handling, reporting, monitoring notice, consequences and escalation, an exception process and a review date. It is grounded in ISO/IEC 27002:2022, NIST SP 800-53 Rev. 5 and related NIST guidance, CIS Controls v8.1, and Indian law.

The policy is designed to be practical. It uses specific timeframes, named contacts, a classification table, graduated consequences, a transparent monitoring notice and no-blame reporting. Diagrams, forms and checklists make it usable from day one.

Automated and manual checks confirmed that the policy is complete and internally consistent. They also showed that readability can be improved. The main remaining steps before real-world adoption are legal review, stakeholder consultation and user training.

11. References

1. International Organization for Standardization. (2022). *ISO/IEC 27001:2022 — Information security management systems — Requirements*. ISO.
2. International Organization for Standardization. (2022). *ISO/IEC 27002:2022 — Information security controls*. ISO.
3. Joint Task Force. (2020). *Security and Privacy Controls for Information Systems and Organizations* (NIST SP 800-53 Rev. 5). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-53r5
4. Temoshok, D., et al. (2025). *Digital Identity Guidelines: Authentication and Authenticator Management* (NIST SP 800-63B-4). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-63B-4
5. Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management* (NIST SP 800-61 Rev. 3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3
6. National Institute of Standards and Technology. (2025). *Guidelines for Media Sanitization* (NIST SP 800-88 Rev. 2). https://doi.org/10.6028/NIST.SP.800-88r2
7. Center for Internet Security. (2024). *CIS Critical Security Controls, Version 8.1*. https://www.cisecurity.org/controls
8. SANS Institute. *Security Policy Templates — Acceptable Use Policy*. https://www.sans.org/information-security-policy/
9. Verizon. (2024). *2024 Data Breach Investigations Report*. https://www.verizon.com/business/resources/reports/dbir/
10. Government of India. (2000). *The Information Technology Act, 2000*. https://www.indiacode.nic.in/
11. Government of India. (2023). *The Digital Personal Data Protection Act, 2023*. https://www.meity.gov.in/
12. Indian Computer Emergency Response Team (CERT-In). (2022, April 28). *Directions under sub-section (6) of section 70B of the Information Technology Act, 2000*. https://www.cert-in.org.in/
13. European Parliament and Council. (2016). *Regulation (EU) 2016/679 (General Data Protection Regulation)*.